

Lateral Movement

(TA0008)

청주대학교 디지털보안학과 시스템보안실습

Lateral Movement

- The adversary is **trying to move through your environment**.

Lateral Movement

- Lateral Movement consists of techniques that adversaries use to enter and control remote systems on a network.
- Following through on their primary objective often requires exploring the network to find their target and subsequently gaining access to it.
- Reaching their objective **often involves pivoting through multiple systems** and accounts to gain.
- Adversaries might **install their own remote access tools** to accomplish Lateral Movement **or use legitimate credentials** with native network and operating system tools, which may be stealthier.

Pivot

- The act of an attacker moving from one compromised system to one or more other systems within the same or other organizations.
- Pivoting is fundamental to the success of advanced persistent threat (APT) attacks.
- SSH trust relationships may more readily allow an attacker to pivot.
- <https://csrc.nist.gov/glossary/term/pivot>

LM: Techniques

- Exploitation of Remote Services
- Internal Spearphishing
- Lateral Tool Transfer
- Remote Service Session Hijacking
- Remote Services
- Replication Through Removable Media
- Software Deployment Tools
- Taint Shared Content
- Use Alternate Authentication Material

LM: Remote Services

- Adversaries may use Valid Accounts to log into a service that accepts remote connections, such as telnet, SSH, and VNC.
- The adversary may then perform actions as the logged-on user.

LM: Remote Services

- In an enterprise environment, servers and workstations can be organized into **domains**.
- Domains provide centralized identity management, **allowing users to login using one set of credentials across the entire network**.
- If an adversary is able to obtain a set of valid domain credentials, they could login to many different machines using remote access protocols such as secure shell (SSH) or remote desktop protocol (RDP).
- They could also login to accessible SaaS or IaaS services, such as those that federate their identities to the domain.

LM: Remote Services

- Legitimate applications may **utilize Remote Services** to access remote hosts.
- For example, Apple Remote Desktop (ARD) on macOS is native software used for remote management.
- ARD leverages a blend of protocols, including VNC to send the screen and control buffers and SSH for secure file transfer.
- Adversaries can abuse applications such as ARD to gain remote code execution and perform lateral movement.
- In versions of macOS prior to 10.14, an adversary can escalate an SSH session to an ARD session which enables an adversary to accept TCC (Transparency, Consent, and Control) prompts without user interaction and gain access to data.

LM: Remote Services: Sub-techniques

- Remote Desktop Protocol
- SMB/Windows Admin Shares
- Distributed Component Object Model
- SSH
- VNC
- Windows Remote Management
- Cloud Services
- Direct Cloud VM Connections

LM: Remote Services: Remote Services: SSH

- Adversaries may use Valid Accounts to log into remote machines using Secure Shell (SSH).
- The adversary may then perform actions as the logged-on user.

LM: Remote Services: Remote Services: SSH

- SSH is a protocol that allows authorized users to open remote shells on other computers.
- Many Linux and macOS versions come with SSH installed by default, although typically disabled until the user enables it.
- The SSH server can be configured to use standard password authentication or public-private keypairs in lieu of or in addition to a password.
- In this authentication scenario, the user's public key must be in a special file on the computer running the server that lists which keypairs are allowed to login as that user.